

TSEC Risk & Cyber Advisory

www.tsecgrc.com | Info@tsecgrc.com

T R A I N I N G M O D U L E

Phishing Awareness Training

TSEC Security Awareness Series | Identification Techniques & Reporting Procedures

Document Version	1.0
Effective Date	September 2026
Classification	PUBLIC
Prepared by	TSEC Risk & Cyber Advisory LLC
Review Cycle	Annual

© 2026 TSEC Risk & Cyber Advisory LLC. All rights reserved. Free to distribute unmodified within your organization; not for resale.

TSEC Technical Data Sheet

Every resource published in the TSEC Compliance Library™ includes this standardized technical data sheet, summarizing the resource's identity, scope, and intended use at a glance.

Library	TSEC Security Awareness Series
Framework	General Security Awareness Best Practice
Publication	Training Module
Category	Security Awareness & Training
Resource Name	Phishing Awareness Training
Document Type	Training Module
File Format	PDF / DOCX
Tier	Free Resource
Editable	Yes — customize for your organization before deployment
Language	English
Target Audience	All Employees
Cross-Mapped Frameworks	NIST CSF 2.0 (PR.AT), ISO/IEC 27001 Annex A (Awareness, Education and Training)
Approval Authority	TSEC Risk & Cyber Advisory LLC
Review Frequency	Annual
Owner	TSEC Risk & Cyber Advisory LLC
Version	1.0
Status	Published
License	TSEC Resource Library — free distribution, unmodified

Contents

TSEC Technical Data Sheet	2
Contents	3
About This Training	4
01. What Is Phishing?	4
02. Why Phishing Works	4
03. Common Types of Phishing Attacks	4
04. Red Flags Checklist	5
05. Real-World Examples (Illustrative)	6
Example 1 — Fake IT Alert	6
Example 2 — Fake Executive Request	6
06. What to Do If You Suspect Phishing	6
07. Step-by-Step Reporting Procedure	6
08. What Happens After You Report	7
09. Knowledge Check	7
1. An email from “IT Support” asks you to confirm your password by clicking a link within one hour or lose account access. What should you do first?	7
2. Which of these is the strongest single red flag in a message?	7
3. A “vendor” calls asking you to verbally confirm banking details to update an invoice. This is an example of:	7
4. You already clicked a link and entered your password before realizing something felt wrong. What should you do?	8
5. A message creates urgency, comes from an unfamiliar address, and asks you to purchase gift cards for an executive. This most closely matches:	8
Answer Key	8
10. Quick Reference Card	8
11. Training Acknowledgment	8
12. From Awareness to Simulation	9
Revision History	9

About This Training

This module is a ready-to-deploy phishing awareness training for all employees. It covers what phishing is, how to recognize it, and exactly what to do when you spot it — in plain language, with no technical background required.

Organizations may customize the placeholders in this module (such as the reporting contact and escalation channel) and distribute it as part of onboarding or recurring security awareness training. This module covers awareness and reporting; it is not a substitute for a structured phishing simulation program.

01. What Is Phishing?

Phishing is a social engineering attack in which someone impersonates a trusted person, brand, or system to trick you into taking an action that helps them — clicking a link, opening an attachment, entering credentials, or transferring money or data.

Phishing does not rely on breaking technical defenses. It relies on **you** — your trust, your urgency to help, or your desire to avoid a problem. That's exactly why awareness is one of the most effective controls an organization has.

02. Why Phishing Works

Effective phishing attempts exploit predictable human responses rather than technical flaws:

- **Urgency** — “Your account will be suspended in 24 hours” pressures you to act before you think.
- **Authority** — a message appearing to come from an executive, IT, or a vendor makes you less likely to question it.
- **Fear** — threats of penalties, account loss, or legal consequences push people toward quick compliance.
- **Curiosity or reward** — an unexpected invoice, delivery notice, or prize invites a click before you've considered why you received it.
- **Familiarity** — attackers copy real logos, signatures, and writing styles from your actual vendors and colleagues.

Recognizing **which emotion a message is trying to trigger** is often a faster warning sign than trying to spot a technical flaw in the email itself.

03. Common Types of Phishing Attacks

Type	Description	Typical Vector
------	-------------	----------------

Type	Description	Typical Vector
Email Phishing	Mass, generic messages impersonating a known brand or service, sent to many recipients.	Email
Spear Phishing	Targeted messages personalized with details about you or your organization.	Email
Whaling	Spear phishing aimed at executives or other high-value targets.	Email
Business Email Compromise (BEC)	Impersonation of an executive or vendor requesting a wire transfer, gift cards, or a change to payment details.	Email
Smishing	Phishing delivered via SMS text message, often with a shortened or disguised link.	Text Message
Vishing	Phishing conducted over a phone call, often impersonating IT support or a bank.	Phone Call
Clone Phishing	A near-identical copy of a legitimate email you previously received, with the link or attachment swapped for a malicious one.	Email

04. Red Flags Checklist

Most phishing attempts show at least one of these signs. No single flag proves an email is malicious — but more than one should make you stop and verify before acting.

Category	What to Look For
Sender	Display name looks right, but the actual email address is slightly off, misspelled, or from an unrelated domain.
Urgency	Pressure to act immediately — account suspension, missed payment, security alert, executive request with a tight deadline.
Links	Hovering over a link shows a destination that doesn't match the text or the organization it claims to be from.
Attachments	Unexpected attachments, especially invoices, “secure documents,” or files requiring you to “enable content” or log in to view them.
Requests	Requests for credentials, payment details, gift cards, wire transfers, or changes to banking information.
Tone and grammar	Generic greetings, unusual phrasing, or a tone that doesn't match how the sender normally communicates.
Channel mismatch	A request arrives by a channel the sender doesn't normally use — for example, a “CEO” emailing from a personal address instead of the usual internal system.

05. Real-World Examples (Illustrative)

The examples below are constructed for training purposes to illustrate common patterns — they are not reproductions of any actual message.

Example 1 — Fake IT Alert

“Your mailbox has exceeded its storage limit. Click below within 24 hours to avoid losing access to your account.”

- Red flags: urgency, a generic “IT” sender with no personal detail, a link that doesn't point to your organization's actual domain.

Example 2 — Fake Executive Request

“Are you available? I need you to purchase gift cards for a client appreciation event — send the codes as soon as you have them, I'm in meetings all day.”

- Red flags: unusual request for a senior executive to make directly, urgency combined with unavailability (so you can't easily verify by calling), a request that bypasses normal purchasing procedures.

06. What to Do If You Suspect Phishing

- **Don't click** any link or open any attachment in the message.
- **Don't reply** to the sender, even to question it — this confirms your address is active and monitored.
- **Verify independently** — if the message claims to be from a colleague, vendor, or executive, contact them through a separate, known channel (phone, a new email you initiate, in person).
- **Report it** using the procedure in the next section, even if you're not certain it's malicious.

If you already clicked a link, opened an attachment, or entered credentials, **report it immediately** — speed matters far more than avoiding embarrassment. Every reported incident helps protect the rest of the organization.

07. Step-by-Step Reporting Procedure

1. **Step 1 — Do not interact further** with the message, link, or attachment.
2. **Step 2 — Report the message** using your organization's reporting method: [Report Phishing button / forward to security@[organization].com / IT Help Desk ext. [XXXX]].
3. **Step 3 — Include context** if asked — when you received it, whether you clicked anything, and whether you entered any information.
4. **Step 4 — If credentials were entered**, change the affected password immediately and notify your reporting contact so any affected account can be secured.

5. **Step 5 — Do not forward the message** to coworkers to warn them informally — let the security team issue any broader alert, since informal forwarding can spread the malicious link further.

08. What Happens After You Report

Reporting starts a defined process, not just a filed complaint:

- The security team reviews the message and determines whether it is malicious, and whether it was sent to other employees.
- If credentials or data may have been exposed, the affected account is secured and monitored.
- If the same message was sent broadly, the team can block the sender and warn other recipients before they interact with it.
- Reported messages inform future awareness training and, in aggregate, help the organization measure and improve its phishing resilience over time.

There is no penalty for reporting a message that turns out to be legitimate. The goal is more reports, not fewer.

09. Knowledge Check

Answer each question, then check your responses against the answer key at the end of this section.

1. An email from “IT Support” asks you to confirm your password by clicking a link within one hour or lose account access. What should you do first?

- a) Click the link right away to avoid losing access
- b) Reply asking if the email is legitimate
- c) Do not click; verify through a known IT channel and report the message
- d) Forward it to coworkers to see if they got it too

2. Which of these is the strongest single red flag in a message?

- a) The email uses your first name
- b) The sender's display name matches a colleague, but the actual address is from an unrelated domain
- c) The email was sent during business hours
- d) The email includes a company logo

3. A “vendor” calls asking you to verbally confirm banking details to update an invoice. This is an example of:

- a) Smishing
- b) Whaling
- c) Vishing
- d) Clone phishing

4. You already clicked a link and entered your password before realizing something felt wrong. What should you do?

- a) Say nothing and hope it was fine
- b) Wait to see if anything unusual happens first
- c) Report it immediately and change the password
- d) Delete the email so there's no record

5. A message creates urgency, comes from an unfamiliar address, and asks you to purchase gift cards for an executive. This most closely matches:

- a) Smishing
- b) Business Email Compromise (BEC)
- c) Vishing
- d) Clone phishing

Answer Key

1 — c | 2 — b | 3 — c | 4 — c | 5 — b

10. Quick Reference Card

If it feels urgent	Slow down — urgency is the most common manipulation tactic.
Check the sender	Verify the actual email address, not just the display name.
Don't click blindly	Hover over links before clicking; confirm the destination matches the claimed sender.
Verify unusual requests	Confirm payment, credential, or gift card requests through a separate, known channel.
Report every time	[Report Phishing button / security@[organization].com / IT Help Desk ext. [XXXX]]
Already clicked?	Report immediately — speed matters more than avoiding embarrassment.

11. Training Acknowledgment

Organizations may use the fields below to document completion of this training as part of onboarding or annual security awareness requirements.

Employee Name	_____
Department	_____
Date Completed	_____
Signature	_____

12. From Awareness to Simulation

This module builds baseline awareness. Measuring and improving real-world resilience — tracking who clicks, who reports, and how that changes over time — requires an ongoing phishing simulation program.

Explore the TSEC Security Awareness Training Module Pack™

A complete awareness program: simulated phishing campaigns, role-based training tracks, reporting-rate metrics, and board-ready security awareness reporting built on the concepts in this module.

Info@tsecgrc.com | www.tsecgrc.com

Revision History

Version	Date	Author	Summary of Changes
1.0	September 2026	TSEC Risk & Cyber Advisory LLC	Initial publication of the Phishing Awareness Training module.